

BigPanda

On-Prem Worker

Security Trust & Compliance Brief

1. Executive Summary

The BigPanda On-Prem Worker is an additional platform product that consists of a lightweight, customer-deployed Docker agent that executes customer-authored runbooks. It acts as the execution engine for automated collection of diagnostic and contextual data related to incidents.

This document describes the security architecture, data handling practices, shared responsibility model, and compliance posture of the On-Prem Worker to provide customers with the transparency and assurance required for deployment in enterprise environments.

2. Product Overview

What Is the On-Prem Worker?

The On-Prem Worker is a containerized Docker agent that customers download and deploy within their own infrastructure, whether on-premises data centers, private clouds, or public cloud environments.

The On-Prem Worker operates on a read-only, information-gathering model. It connects to customer systems exclusively to collect diagnostic and contextual information relevant to the incident. It does not remediate, modify, or alter any systems or data. All access is governed by customer-defined roles, and all execution is bounded by customer-authored runbook logic.

How It Works

1. A BigPanda incident ticket is created and routed based on the defined routing management scheme.
2. Kafka triggers creation of a customer-dedicated AI Triage Master Agent which is associated to the incident. The AI Triage Master Agent spins up an AI Sub-Agent to manage workflow execution.
3. **The AI Triage Master Agent:**
 - a. Gathers incident information for context.
 - b. Queries VectorDB and Neo4j DB, gathering component-level associations and applicable runbook(s).
 - c. Engages the LLM, sharing applicable information to generate an explicit workflow for On-Prem Worker execution.
4. The generated workflow is transmitted to the AI Sub-Agent to be added to the Temporal server. The AI Sub-Agent maintains communication, awaiting response from the On-Prem Worker.
5. **The On-Prem Worker:**
 - a. Authenticates with the Temporal server, retrieving the workflow.
 - b. Assumes a customer-controlled role with access and permissions to execute the workflow, gathering applicable information.
 - c. The On-Prem Worker securely transmits the applicable information to the Temporal server.
6. The AI Sub-Agent transmits the applicable information to the AI Triage Master Agent, terminating upon successful transmission.
7. The AI Triage Master Agent writes the runbook steps executed by the On-Prem Worker and the resulting information gathered, terminating upon successful transmission.

3. Security Architecture

Key Security Principles

- **Customer-Deployed:** The worker runs entirely within the customer's environment. BigPanda does not host or operate the worker on behalf of the customer.
- **Customer-Authored Runbooks:** All runbook logic is created, maintained, and owned by the customer. BigPanda does not author, modify, or inject runbook steps.
- **Customer-Configured Outbound Connection Only:** The worker operates over a customer configured outbound ONLY mTLS connection to BigPanda. There is no inbound connectivity.
- **Customer-Controlled Access:** All permissions and credentials for the worker are provisioned by the customer through role assumption. BigPanda never stores or manages customer infrastructure credentials.
- **Read-Only Operations:** The worker's intended function is information gathering. It reads data from systems; it does not write, update, delete, or move data.
- **Data-in-Place Processing:** The worker accesses and processes data at its origin. It does not replicate, copy, or relocate data between systems or environments.

Identity and Access Management

The On-Prem Worker does not maintain standing credentials to customer systems. All access is obtained through role assumption, where the worker requests temporary, scoped credentials from the customer's identity provider at the time of execution.

- **Role Assumption:** The customer defines a service role with the minimum permissions required for runbook execution. The worker assumes this role at runtime to successfully execute the defined workflow.
- **Least Privilege:** The customer is responsible for scoping the assumed role to only the systems and data required by their runbooks. BigPanda provides guidance on recommended permission scoping.
- **No Credential Storage:** The worker does not store, cache, or persist any credentials beyond the active execution session. Credentials are held in memory only for the duration of the runbook execution.
- **Credential Rotation:** Customer fully control credential rotation for the worker according to their internal security requirements.

Network Security

The On-Prem Worker operates entirely within the customer's network perimeter. All communications between the worker and customer systems are subject to the customer's network policies, firewall rules, and segmentation controls.

- **Encrypted Communications:** All communications between BigPanda and the worker use TLS 1.2 or higher. The worker validates certificates to prevent man-in-the-middle attacks.
- **Outbound-Only Connectivity:** The worker initiates outbound connections to BigPanda over mTLS. No inbound ports are required to be opened in the customer's firewall for BigPanda to communicate with the worker.
- **Network Isolation:** The worker can be deployed in an isolated network segment with access limited to only the systems required by the customer's runbooks, in accordance with customer network architecture.

Data Protection

Data-in-Place Processing

The On-Prem Worker adheres to a strict data-in-place processing model. Data accessed during runbook execution is read and processed at its origin. The worker does not copy, replicate, or move data between systems, storage locations, or environments. Diagnostic results are structured summaries, not raw data exports.

Data in Transit

All data transmitted between the worker and BigPanda is encrypted using TLS 1.2+ with strong cipher suites. Execution requests and results are transmitted over mutually authenticated encrypted channels.

Data at Rest

The On-Prem Worker does not persist data at rest. Execution context, gathered information, and credentials exist only in memory for the duration of the runbook execution. Upon completion or failure, all in-memory data is released. No local logging of sensitive operational data occurs on the worker.

Data Minimization

The worker collects only the information specified by the runbook steps authored by the customer. It does not perform broad discovery, scanning, or enumeration beyond the explicit instructions in the runbook. The customer controls what data is gathered by controlling the runbook content.

5. Shared Responsibility Model

Security of the On-Prem Worker deployment operates under a shared responsibility model. BigPanda is responsible for the security of the worker software itself. The customer is responsible for the security of the environment in which it runs and the access it is granted.

BigPanda Responsibilities

- **Secure Development Lifecycle (SDLC):** BigPanda is responsible for the full SDLC process to ensure the On-Prem Worker is free of vulnerabilities. This includes threat modeling, secure coding practices, static and dynamic analysis, dependency scanning, peer code review, and penetration testing prior to every release.
- **Worker Software Security:** BigPanda develops, tests, and maintains the On-Prem Worker software. Vulnerability management is a core obligation. BigPanda continuously monitors for known vulnerabilities in the worker codebase and its dependencies and remediates according to documented severity-based SLAs.
- **Secure Communication Protocol:** BigPanda maintains the encrypted communication channel between the BigPanda platform and the worker, including certificate management for the BigPanda-side endpoints.
- **Security Updates and Advisories:** BigPanda releases security patches and advisories for the worker and notifies customers of required updates through standard communication channels.
- **Audit Trail:** BigPanda logs the end-to-end process within our platform for customer review and troubleshooting purposes.

Customer Responsibilities

- **Runbook Authoring and Review:** The customer is solely responsible for creating, reviewing, and maintaining runbooks. Runbooks define what systems the worker connects to, what data it gathers, and what actions it takes. BigPanda does not review or validate runbook content for security.
- **Incident-Runbook Associations:** The customer configures which runbooks are triggered for which incident types. Accurate association ensures the correct diagnostic steps are executed for each incident.
- **Role Provisioning and Scoping:** The customer defines and provisions the service role that the worker assumes. The customer is responsible for applying least-privilege principles and scoping permissions to only the systems and data required by their runbooks.
- **Credential and Identity Infrastructure:** The customer maintains the identity provider and role assumption infrastructure. This includes configuring trust policies, session duration limits, and any conditional access policies.
- **Network Security:** The customer is responsible for the network environment in which the worker operates, including firewall rules, network segmentation, DNS resolution, and monitoring of network traffic.
- **Host and Container Security:** The customer manages the compute environment running the worker container, including host OS patching, container runtime security, and resource isolation.
- **Worker Updates:** The customer is responsible for applying worker updates released by BigPanda in a timely manner. Running outdated versions may expose the environment to known vulnerabilities.
- **Monitoring and Alerting:** The customer is responsible for monitoring the worker's operational behavior within their environment, including resource consumption, unexpected network connections, and execution anomalies.

6. Compliance and Trust Posture

The BigPanda platform, which dispatches execution requests to the On-Prem Worker, maintains compliance with industry-recognized frameworks. BigPanda undergoes annual SOC 2 Type II audits covering security, availability, and confidentiality trust service criteria. The On-Prem Worker development and release processes are within the audit scope.

7. Operational Security Guidance

BigPanda recommends the following security practices for customers deploying the On-Prem Worker.

Deployment Best Practices

- **Image Verification:** Always verify the container image before deployment.
- **Dedicated Service Account:** Create a dedicated service identity for the worker. Do not reuse identities shared with other services or human users.
- **Network Segmentation:** Deploy the worker in an isolated network segment with access limited to only the systems required by active runbooks.
- **Resource Limits:** Configure CPU and memory limits on the worker container to prevent resource exhaustion and contain any unexpected behavior.
- **Update Cadence:** Establish a process to apply BigPanda-released worker updates within your organization's patch management SLA.

Role Scoping Recommendations

- **Start Minimal:** Begin with the narrowest permissions possible and expand only as specific runbooks require additional access.
- **Read-Only by Default:** The worker's intended function is information gathering. Scope the role to read-only permissions unless a runbook explicitly requires write access for a documented, approved purpose.
- **Session Duration:** Configure the shortest practical session duration for assumed role credentials. Align with your organization's session management policies.
- **Conditional Access:** Where supported by your identity provider, apply conditional access policies to the worker's role (source IP restrictions, time-of-day constraints, MFA requirements for role assumption).

Runbook Governance

- **Peer Review:** Require peer review for all runbook changes before deployment, following the same rigor applied to infrastructure-as-code.
- **Version Control:** Maintain runbooks in version control with a complete audit trail of changes, approvals, and deployments.
- **Testing:** Test runbooks in a non-production environment before associating them with production incident types.
- **Periodic Review:** Review active runbooks on a regular cadence to ensure they remain aligned with current infrastructure, access policies, and operational requirements.

8. Frequently Asked Questions

Question	Answer
Does BigPanda have access to my systems?	No. The On-Prem Worker runs in your environment using credentials you provision. BigPanda does not have direct access to your infrastructure.
Can the worker modify my systems?	The worker is designed for read-only information gathering. It does not modify systems unless a customer-authored runbook explicitly instructs it to do so. BigPanda recommends scoping the assumed role to read-only permissions.
Where does my data go?	Data is processed in-place within your environment. Only structured diagnostic results specified by your runbook are returned to BigPanda over an encrypted channel.
How do I control what the worker can access?	You control access entirely through role provisioning. The worker can only access systems and data that the assumed role permits. Apply least-privilege principles when defining the role.
Does BigPanda write or modify my runbooks?	No. All runbooks are authored, maintained, and owned by you. BigPanda provides the execution engine but does not create, modify, or inject runbook logic.
How are worker updates delivered?	BigPanda releases updated container images. You download and deploy updates according to your organization's change management process.